Análisis dinámico: del comportamiento observado al veredicto

De la capacidad al comportamiento

En la lección anterior se analizó una muestra **sin ejecutarla**. El resultado fue una lista de capacidades: «contiene una clave de autoarranque», «contiene nombres de funciones de red», «referencia un dominio». Ninguna de esas frases decía qué **hace** la muestra. El análisis estático terminó con una recomendación: diseñar una prueba dinámica.

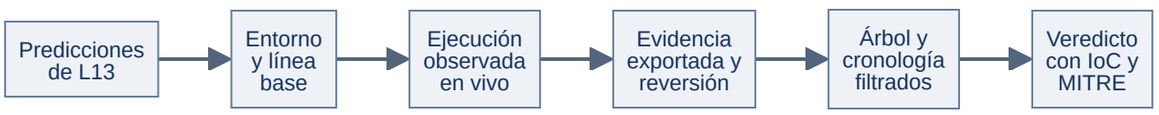
Esta lección trabaja con el resultado de esa prueba. La pregunta es:

> ¿Qué hizo realmente la muestra cuando se ejecutó, qué no pudo verse y cuánto cambia eso el veredicto?

Cuatro ideas ordenan la lección:

1. **ejecutar exige un entorno controlado**: aislamiento, estado limpio, monitoreo, criterio de detención y reversión verificada;
2. **una traza muestra lo que se monitoreó, no todo lo que pasó**: lo que no se registró no puede declararse ausente;
3. **el árbol de procesos separa la muestra del ruido**: el árbol permite atribuir actividad directa a la muestra y sus descendientes; algunos servicios pueden actuar por encargo;
4. **observar un comportamiento no revela la intención**: «escribió una clave de autoarranque» es un hecho; «quería persistir para robar datos» es una interpretación.

En el curso se ejecuta una **variante didáctica** de la muestra de la lección 13: un programa benigno, preparado para la clase, que reproduce el comportamiento de un malware simple de forma acotada y reversible. Se trata igual que una muestra real: en una máquina de análisis aislada, con snapshot, red simulada y reversión verificada.



1. Qué responde el análisis dinámico

	Análisis estático (L13)	**Análisis dinámico (L14)**
Pregunta	¿Qué es y qué **podría** hacer?	¿Qué **hizo** en esta ejecución?
Evidencia	Bytes del archivo: firma, cadenas, estructura	Eventos registrados mientras corría
Lenguaje	«contiene», «es compatible con»	«creó», «escribió», «se conectó», siempre con hora y fuente
Límite	No ve comportamiento	Solo ve **esa** ejecución, en **ese** entorno, durante **esa** ventana

El análisis dinámico no reemplaza al estático: lo **contrasta**. Las predicciones del estático dicen qué buscar en las trazas; las trazas confirman algunas, dejan otras sin observar y, a veces, muestran comportamientos que nadie predijo.

2. El entorno controlado

NIST SP 800-83 recomienda analizar malware en entornos que no puedan dañar sistemas de producción ni alcanzar redes reales. Un entorno controlado reúne siete elementos:

Elemento	**Qué es**	**Por qué importa**
Máquina virtual desechable	Equipo de laboratorio sin datos ni usos reales	Lo que la muestra dañe no importa
Snapshot previo	Copia del estado limpio, tomada antes de ejecutar	Permite volver exactamente al punto de partida
Red aislada o simulada	Red interna sin salida; un simulador (por ejemplo, INetSim) responde DNS y HTTP	La muestra «cree» que tiene Internet, pero no alcanza a nadie

Elemento	Qué es	Por qué importa
Cuenta local sin credenciales reales	En esta práctica, cuenta `analista` con UAC; la muestra se ejecuta sin elevar y Procmon requiere elevación	Separa los permisos de monitoreo de los del programa analizado
Monitoreo definido de antemano	Qué se registrará: procesos, archivos, registro, DNS, red	Lo que no se configura no queda registrado
Criterio de detención	Tiempo límite y condiciones de corte (cifrado, propagación, salida de la red)	Evita que la prueba se descontrole
Reversión verificada	Restaurar el *snapshot* y comprobar que no quedaron artefactos	Sin verificación, el «entorno limpio» de la próxima prueba es un supuesto

Las distribuciones REMnux (Linux) y FLARE-VM (Windows) reúnen herramientas para este trabajo. El laboratorio del curso es una versión mínima de esa idea: una máquina Windows desechable con las herramientas Sysinternals y una Kali que simula Internet con INetSim y captura la red con Wireshark.

El protocolo es evidencia

El registro de cómo se ejecutó la muestra es tan importante como lo observado. Responde: quién ejecutó, cuándo, en qué entorno, con qué herramientas, por qué se detuvo y cómo se revirtió. Sin ese registro, una captura no se puede interpretar: no se sabe qué podía verse ni si el entorno estaba limpio. En la práctica, los pasos 1 a 4 de la plantilla de entrega cumplen ese papel.

3. Herramientas de observación

Ninguna herramienta ve todo lo que hace una muestra. Un análisis dinámico combina varias que miran desde lados distintos:

Herramienta	Mira	Ve	No ve
Process Monitor (Sysinternals)	El sistema de archivos, el registro, los procesos y la red, evento por evento	Qué tocó cada proceso, con hora, ruta y resultado; guarda la historia completa	Objetos en memoria (*mutex*); el contenido de lo enviado por red
Process Explorer (Sysinternals)	Los procesos que existen **ahora**	Árbol con padres e hijos, objetos abiertos (*handles*), como el *mutex*	Lo que ya terminó: no guarda historia
Autoruns (Sysinternals)	Los lugares de inicio automático	Claves `Run`, servicios, tareas; compara contra una línea base	Si la entrada llega a ejecutarse
Wireshark	La red	Consultas DNS, solicitudes y su contenido, tiempos entre paquetes	Qué proceso envió cada paquete
INetSim y **dnsmasq**	Lo que llega al «Internet» simulado	Solicitudes web recibidas (INetSim) y nombres consultados (dnsmasq)	Nada de lo que pasa dentro de Windows

Por eso un mismo hecho se confirma con dos herramientas cuando se puede: la conexión aparece en Procmon (`TCP Connect`), en Wireshark y en el registro de INetSim. Y una pregunta sin herramienta que la cubra queda **no evaluable**: si nadie mira los *mutex*, no se puede decir nada de ellos.

Una particularidad de Windows: el DNS

En el ensayo del laboratorio, el servicio **Cliente DNS** (`svchost.exe`) envía las consultas solicitadas por la muestra. Al filtrar Procmon por la muestra y sus descendientes, esa actividad delegada queda fuera del árbol; puede verse en Wireshark y en el registro de **dnsmasq**, que presta el servicio DNS en esta práctica. INetSim recibe HTTP y HTTPS, no las consultas DNS. Herramientas como **Sysmon** pueden aportar atribución mediante el evento 22 si estaban instaladas y configuradas para registrar consultas; no se utiliza Sysmon en esta actividad.

Responder no es existir

INetSim acepta cualquier solicitud y responde `200`. Eso solo dice que la conexión se completó dentro del laboratorio, no que exista un servidor real ni qué haría ese servidor.

4. Lo que la traza no muestra

Toda conclusión dinámica tiene tres límites:

1. **Cobertura de las herramientas.** Procmon no registra *mutex*: si solo se usó Procmon, la ausencia de un *mutex* no dice nada.

2. **Ventana temporal.** Una ejecución de cuatro minutos no ve lo que la muestra haría a los diez minutos, al reiniciar o al día siguiente.
3. **Entorno.** Algunas muestras detectan que corren en una máquina virtual, esperan antes de actuar o necesitan un servidor real que responda algo concreto. Lo que no hicieron en el laboratorio podrían hacerlo en un equipo real.

Por eso se distinguen dos resultados que parecen iguales y no lo son:

Resultado	Significa	Ejemplo
No observado	Una herramienta usada podía registrarlo y no aparece en la ventana	Procmon no muestra escrituras en `C:\Program Files`, y Procmon registra escrituras de archivos
No evaluable	Ninguna herramienta usada cubría ese tipo de acción	Se usó solo Procmon y la predicción era un *mutex*

«No observado» tampoco es «descartado»: es una afirmación limitada a esa ejecución y esa ventana.

5. El árbol de procesos

Una traza de host mezcla la actividad de la muestra con la del sistema operativo: indexación, actualizaciones, servicios. Separarlas es el primer paso del análisis.

Cada creación de proceso registra dos números:

- **PID**: identificador del proceso creado;
- **PPID**: identificador de su proceso padre.

Siguiendo los PPID se construye la **genealogía**:

```
explorer.exe (PID 1800)                ← el usuario hace doble clic
└── informe-pagos.exe (PID 2200)       ← la muestra
    └── [hijos de la muestra, si los hay]
```

El PID de la muestra y los de sus descendientes permiten seleccionar su actividad directa. Un `svchost.exe` cuyo padre es `services.exe` pertenece a un servicio del sistema y no se incorpora automáticamente al árbol de la muestra. Sin embargo, ese servicio puede actuar por encargo, como ocurre con el DNS: estar fuera del árbol no demuestra que toda su actividad sea ajena al caso. Hay que correlacionar nombre consultado, destino y hora con la red.

Procmon aplica esta regla con *Tools* > *Process Tree* > *Include Subtree*: filtra la muestra y todos sus descendientes de una vez. Process Explorer muestra el mismo árbol en vivo.

Dos precauciones:

- **Los PID se reutilizan.** Un PID identifica a un proceso solo mientras existe; en trazas largas se combina con la hora de creación.
- **El padre importa.** `cmd.exe` es común; `cmd.exe` cuyo padre es un supuesto PDF no lo es.

6. La cronología de comportamiento

La bitácora de comportamiento es una tabla de **hechos** ordenados en el tiempo. Cada fila tiene hora, fuente, categoría (proceso, archivo, registro, red) y lo observado, sin interpretación.

Hora	Fuente	Categoría	Hecho observado
09:00:01	Procmon	Registro	La muestra escribe `...\CurrentVersion\Run\PagosSync` con valor `...\sync.exe`

Frente a ella, una fila mal escrita: «09:00:01 - instala persistencia para sobrevivir al reinicio». Mezcla el hecho con la intención y afirma algo que no se observó (no hubo reinicio).

Corroborar con la segunda fuente

Cuando el host dice «conexión a `10.66.0.1:443` a las 09:00:03» y el simulador dice «solicitud a `pagos-sync.cerro-verde.invalid` a las 09:00:03», los dos registros se refuerzan: dos fuentes independientes coinciden en hora y destino. El simulador agrega además lo que el host no muestra, como el método, la ruta o el tamaño enviado. Para unirlas, ambas deben usar la misma zona horaria; si no, se normalizan primero (lección 12).

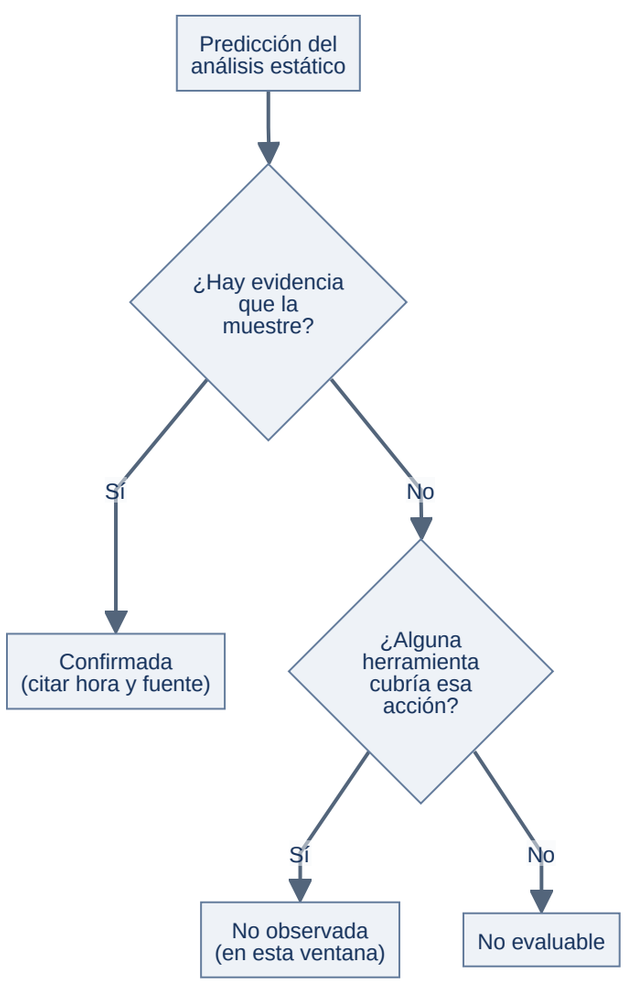
7. Comportamientos frecuentes y cómo leerlos

Observación	Es compatible con	No demuestra por sí sola
Escribir un valor en `...\CurrentVersion\Run`	Persistencia	Que se ejecutó al reiniciar (hay que reiniciar para verlo)
Copiarse a sí misma (mismo hash) en el perfil del usuario	Preparación de persistencia o de ocultamiento	Que la copia se ejecutó
Lanzar `cmd.exe` con un comando como `systeminfo`, `whoami` o `ipconfig`	Descubrimiento de información del sistema	Que esa información se envió
Consultar un dominio y conectarse	Comunicación de red; posible mando y control	Qué datos se enviaron o recibieron
Conexiones repetidas a intervalos regulares	Balizamiento (*beaconing*): la muestra «se reporta»	Que haya un operador remoto
Una solicitud grande seguida de otras pequeñas	Registro inicial y luego latidos	Que la primera contenga datos robados
Cifrar o borrar archivos en masa	Impacto	— (sería criterio de detención inmediata)

La periodicidad se detecta mirando las horas: seis conexiones a :09 y :39 de cada minuto indican un intervalo de 30 segundos. Un programa legítimo también puede reportarse periódicamente (telemetría, licencias), y por eso el contexto importa.

8. Predicción frente a observación

El análisis dinámico cierra el ciclo abierto por el estático. Cada predicción de la lección 13 recibe uno de tres estados:



Dos casos merecen atención:

- **Confirmación parcial.** Si la predicción era «podría persistir» y la traza muestra la escritura de la clave, se confirma la **escritura**; que la persistencia funcione (que la muestra vuelva a ejecutarse al iniciar sesión) sigue sin comprobarse.
- **Comportamiento no predicho.** Si la traza muestra algo que el estático no anticipó (por ejemplo, una autocopia), se registra como hallazgo nuevo. Es una señal de que las cadenas no contaban toda la

historia.

También se contrastan las **explicaciones alternativas**. Si el estático propuso «podría ser un instalador legítimo», el dinámico puede hacerla más o menos plausible: algunos instaladores escriben en carpetas de programas o crean servicios, pero otros funcionan dentro del perfil del usuario y usan telemetría. Ni una ruta de usuario ni la periodicidad permiten descartar por sí solas una explicación legítima; hay que considerar la procedencia, la autorización y el conjunto del comportamiento.

9. IoC de comportamiento y ATT&CK con evidencia

En el análisis estático los IoC eran **potenciales**. En el dinámico se vuelven **observados**: la muestra escribió esa clave, creó ese archivo, consultó ese dominio. Aun así, cada IoC se documenta con su contexto:

IoC útil (con contexto)	Demasiado genérico por sí solo
Valor `PagosSync` en `...\Run` apuntando a `...\cv\sync.exe`	«Usa la clave Run» (muchos programas legítimos la usan)
SHA-256 de la muestra y de su copia	El nombre `sync.exe` (fácil de cambiar)
Dominio consultado por el proceso de la muestra	Conexión al puerto 443 (se usa habitualmente para HTTPS)
`cmd.exe /c systeminfo` como hijo de la muestra	«Ejecuta `cmd.exe`»

El mapeo a MITRE ATT&CK también cambia: ya no dice «compatible con» a partir de una cadena, sino que cita la **evidencia** (herramienta y dato):

Comportamiento	Técnica	Evidencia
Escribe valor de autoarranque	T1547.001 Registry Run Keys	`registry_set` a las 09:00:01
Se comunica con un dominio por HTTPS	T1071.001 Web Protocols	`network_connect` a las 09:00:03 y solicitud registrada por el simulador

Una técnica sin línea que la respalde (por ejemplo, exfiltración cuando el contenido no se conserva) se presenta, como máximo, como hipótesis con confianza baja.

10. Confianza y veredicto

El veredicto dinámico separa lo mismo que el estático, pero con más evidencia:

Campo	Pregunta
Comportamiento observado	¿Qué hechos muestra la evidencia, con hora y herramienta?
Interpretación	¿Qué significa para la pregunta del caso?
Confianza	¿Cuánto respaldo tiene, y cuánto cambió respecto del estático?
Alternativa	¿Qué explicación benigna sigue en pie, y por qué gana o pierde fuerza?
Limitación	¿Qué no podía ver la prueba (monitoreo, ventana, entorno)?
Recomendación	¿Qué contención o prueba adicional corresponde?

La confianza puede **subir** para los comportamientos (varios hechos corroborados por dos fuentes) y seguir **limitada** para la intención y el impacto. Un veredicto sólido dice ambas cosas: «la muestra configuró una entrada de autoarranque y realizó comunicación periódica con confianza alta; su ejecución al iniciar sesión no se comprobó». Si la captura permite leer el contenido enviado, descríbanlo; si no lo conserva, declaren ese límite.

11. Ejemplo resuelto - muestra CERRO VERDE (ficticia)

En la lección 13, `informe-pagos.docx` resultó ser un PE32 con una clave de autoarranque, el dominio `pagos-sync.cerro-verde.invalid` y nombres de funciones de red y registro. El laboratorio la ejecutó durante 120 segundos con el mismo tipo de entorno del caso del curso.

Trazas

```
09:00:00 process_create pid=2200 ppid=1800 image=...\informe-pagos.exe sha256=3c1f…
09:00:01 file_create    pid=2200 path=C:\Users\lab\AppData\Local\cv\sync.exe sha256=3c1f…
09:00:01 registry_set   pid=2200 key=HKCU\...\CurrentVersion\Run\PagosSync
value=...\cv\sync.exe
09:00:02 process_create pid=2310 ppid=812 image=...\svchost.exe           ← ruido
09:00:03 dns_query      pid=2200 name=pagos-sync.cerro-verde.invalid result=10.66.0.1
09:00:03 network_connect pid=2200 dst=10.66.0.1:443
09:00:05 process_exit   pid=2200 code=0
[simulador] 09:00:03 svc=https host=pagos-sync.cerro-verde.invalid method=GET uri=/cfg
req_bytes=0
```

Predicción frente a observación

Predicción (L13)	Estado	Respaldo
Autoarranque en `...\Run`	Confirmada (escritura)	`registry_set` 09:00:01; no hubo reinicio, su ejecución no se comprobó
Comunicación con el dominio	Confirmada	Host 09:00:03 y simulador 09:00:03
Escritura en el registro (`RegSetValueExW`)	Confirmada	La misma línea de 09:00:01
Instalador legítimo (alternativa)	No observada	Procmon registraba archivos: solo hay una copia en el perfil, nada en carpetas de programas

No predicho: la autocopia `sync.exe` con el mismo hash. **Ruido:** `svchost.exe` (PID 2310), hijo de `services.exe`.

Veredicto

Campo	Contenido
Comportamiento observado	Se copió al perfil, registró la copia en `...\Run`, consultó su dominio, pidió `/cfg` por HTTPS y terminó a los 5 s.
Interpretación	Comportamiento compatible con persistencia y con la obtención de configuración remota.
Confianza	Alta para los comportamientos (dos fuentes); baja para la intención. Sube respecto del estático (media).
Alternativa	Instalador legítimo: pierde fuerza, porque no instaló nada en carpetas de programas y se copió al perfil.
Limitación	120 s, sin reinicio; el simulador no devolvió una configuración real, y la muestra pudo terminar por eso.
Recomendación	Buscar el valor `PagosSync` y el hash en los equipos de la organización; repetir la prueba con reinicio.

Observen la diferencia con el caso del curso: CERRO VERDE no lanza procesos hijos ni se reporta periódicamente. No copien el veredicto; transfieran el razonamiento.

12. Errores frecuentes

- Interpretar trazas sin verificar que la muestra ejecutada es la analizada.
- Atribuir a la muestra eventos de procesos del sistema que no descienden de ella.
- Escribir intenciones en la columna de hechos («para robar», «para ocultarse»).
- Confundir «no observado» con «no ocurrió», o con «no evaluable».
- Afirmar exfiltración porque hubo un envío de bytes, sin conocer el contenido.
- Tomar el `200` del simulador como prueba de un servidor real.
- Usar IoC genéricos (`cmd.exe`, puerto 443) como si identificaran la muestra.
- Mapear técnicas ATT&CK sin citar la evidencia.
- Olvidar la ventana: unos minutos de ejecución no son el comportamiento completo de una muestra.
- Revertir el snapshot antes de exportar la evidencia.
- Buscar el *mutex* después de que la muestra terminó.
- Consultar los dominios del caso «para ver si existen».

13. Lo esencial para la actividad

Las secciones 2, 3, 4, 5 y 8 son las que más se usan en la actividad; el resto es consulta. Lo esencial:

1. los siete elementos de un entorno controlado y por qué la reversión debe verificarse;
2. qué ve y qué no ve cada herramienta (Procmon, Process Explorer, Autoruns, Wireshark, INetSim);
3. la diferencia entre «no observado» y «no evaluable»;
4. cómo se usa el árbol de procesos para separar la muestra del ruido;
5. que una observación describe un hecho y no revela la intención.

Las predicciones que se contrastan en la práctica están en `notas/predicciones-l13.txt` del paquete: no se necesita haber hecho la lección 13.

14. Glosario

Término	Definición
Análisis dinámico	Ejecución controlada de una muestra para observar su comportamiento
Entorno controlado (*sandbox*)	Máquina aislada y desechable preparada para ejecutar muestras
Snapshot	Copia del estado de una máquina virtual para restaurarlo después
Simulador de red	Servicio que responde DNS, HTTP u otros protocolos dentro del laboratorio
Telemetría	Registro automático de eventos de un sistema
Sysmon	Herramienta de Microsoft que registra procesos, archivos, registro y red en Windows de forma permanente
Process Monitor	Herramienta Sysinternals que registra, evento por evento, archivos, registro, procesos y red
Process Explorer	Herramienta Sysinternals que muestra los procesos vivos, su árbol y sus objetos abiertos
Autoruns	Herramienta Sysinternals que lista los lugares de inicio automático y compara estados
Mutex (*Mutant*)	Objeto con nombre que un programa crea para no ejecutarse dos veces a la vez
Línea base	Estado registrado antes de ejecutar, para saber qué cambió
PID / PPID	Identificador de un proceso / de su proceso padre
Árbol de procesos	Genealogía de procesos construida con PID y PPID
Ruido	Actividad del sistema ajena a la muestra
Persistencia	Mecanismo para volver a ejecutarse tras un reinicio o inicio de sesión
Balizamiento (*beaconing*)	Comunicación periódica de una muestra con un servidor
No observado	Acción que el monitoreo podía registrar y no apareció en la ventana
No evaluable	Acción que el monitoreo no cubría
IoC de comportamiento	Indicador observado en la ejecución, documentado con su contexto
Ventana de observación	Tiempo durante el que se registró la ejecución

Fuentes

- NIST SP 800-83 Rev. 1 - Guide to Malware Incident Prevention and Handling. Manejo y análisis seguro de malware.
- Microsoft Sysinternals - Process Monitor. Captura y filtros de eventos.
- Microsoft Sysinternals - Process Explorer. Árbol de procesos y *handles*.
- Microsoft Sysinternals - Autoruns. Puntos de inicio automático.
- Microsoft Sysinternals - Sysmon. Telemetría permanente de procesos, archivos, registro y red.
- INetSim. Simulación de servicios de Internet en laboratorio.
- Wireshark User's Guide. Filtros y *Follow Stream*.
- REMnux Documentation. Entorno de análisis y simulación de servicios de red (INetSim).
- Mandiant FLARE-VM. Entorno Windows para análisis de malware.
- MITRE ATT&CK Enterprise. Tácticas y técnicas para describir comportamiento.
- ISO/IEC 27042:2015 - Analysis and interpretation of digital evidence. Interpretación y límites de la evidencia.